Flag 16 of 18: Cloud SDK Token File Read by the Injected Process

Rogue Synthesis scenario · Cymbal Investments · Google SecOps SIEM

Question

After elevating privileges via process hollowing on the developer workstation, what existing file in the user local cloud SDK configuration directory was read by the injected process to harvest tokens?

Answer

credentials.db

Evidence

- **Hollowing, 20:33:21Z.** Sysmon Event ID 8, tagged T1055.012 Process Hollowing, on `CYM-DEV-WS-019`. Source: `sys_worker.exe` (PID 7140) run by `alex.chen`. Target: `C:\Windows\System32\svchost.exe`, PID 624, running as `NT AUTHORITY\SYSTEM`. The parent was `node.exe` (PID 6720) running the extension daemon.
- **Token read, 20:46:21Z.** The injected `svchost.exe` (`svchost.exe -k netsvcs -p`, PID 624) spawned this command (cmd.exe PID 7890):

```
cmd.exe /c "type C:\Users\alex.chen\.gcloud\credentials.db"
```

The file sits in the gcloud configuration folder and holds the user tokens. It already existed, and the injected process only read it.

How it was found

The file-read search found nothing because the read was done through a command line, not logged as a separate file event. The answer was in `target.process.command_line` of the `cmd.exe launched by svchost.exe` event, found in a host search:

```
principal.namespace = "Cymbal"
AND principal.hostname = "CYM-DEV-WS-019.cymbal.corp" nocase
```

Wrong turns

The answer is a data file, not a program. `sys_worker.exe`, `svchost.exe`, `cmd.exe` and `powershell.exe` were all rejected. Also check the spelling: `credentials.db`.

Lesson

A system process spawning a command shell is a strong sign of injection. Read the command line of the child process.

Next pivot

Find where the stolen tokens were sent shortly afterward.